Module 1: DevSecOps Fundamentals and Secure Coding Practices

1.1 Introduction to DevSecOps

- DevOps vs DevSecOps: Definitions and Differences
- Shift-Left Security: Principles and Benefits
- Overview of Secure Software Development Lifecycle (SSDLC)
- Key Compliance Standards: ISO 27001, NIST, GDPR, HIPAA

1.2 Threat Modeling

- STRIDE and DREAD Models
- Data Flow Diagrams (DFDs)
- Threat Modeling Tools: OWASP Threat Dragon, Draw.io
- Hands-on: Create a threat model for a simple web application

1.3 Secure Coding and Static Analysis

- OWASP Top 10 Explained with Examples
- Secure Coding Principles
- Static Application Security Testing (SAST)
- Tools: SonarQube, Semgrep
- Hands-on: Run SAST and fix issues in a sample codebase

1.4 Software Composition Analysis

- Introduction to Dependency Vulnerabilities

- Software Composition Analysis (SCA) Overview
- Tools: Snyk, OWASP Dependency-Check, Trivy
- Hands-on: Scan open-source dependencies in Node.js or Python

Module 2: Application and Infrastructure Security

2.1 Dynamic Application Security Testing

- DAST vs SAST
- Black-box Testing Concepts
- Tools: OWASP ZAP, Burp Suite
- Hands-on: Scan a vulnerable application (DVWA or Juice Shop)

2.2 Container Security

- Container Lifecycle Risks
- Best Practices for Dockerfiles and Images
- Tools: Trivy, Anchore, Docker Bench for Security
- Hands-on: Scan and harden Docker images

2.3 Infrastructure as Code (IaC) Security

- Risks in Terraform and CloudFormation
- Scanning Tools: tfsec, Checkov, KICS
- Hands-on: Secure a Terraform-based infrastructure

2.4 Secrets Management

- Avoiding Hardcoded Secrets
- Secrets Storage and Rotation
- Tools: HashiCorp Vault, AWS Secrets Manager, GitLeaks
- Demo: Scan and manage secrets securely

Module 3: Network Security, Firewalls, and CI/CD Pipeline Security

3.1 Network Security and Firewalls

- Types: Web Application Firewall (WAF), NACLs, Security Groups, Host Firewalls
- Cloud-native Firewalls (AWS, Azure, GCP)
- ModSecurity and OWASP CRS
- Hands-on:
    - Configure Security Groups and NACLs
    - Deploy WAF rules to block common attack patterns

3.2 Secure CI/CD Pipelines

- CI/CD Threat Surfaces
- Integrating Security into Build and Release
- Git Secret Detection, Policy Gates, and Approval Workflows
- Tools: GitHub Actions, Jenkins, GitLab CI
- Hands-on: Build a CI/CD pipeline with SAST, SCA, and DAST integrated

3.3 Policy as Code

- Policy as Code Overview
- Open Policy Agent (OPA) and Rego
- Kubernetes Admission Controllers with Gatekeeper
- Hands-on: Apply a basic security policy in Kubernetes

Module 4: Logging, Monitoring, Compliance, and Project

4.1 Security Logging and Monitoring

- Importance of Logging: Authentication, Access, Firewall, Application Logs
- Monitoring Tools: ELK Stack, Falco, Prometheus, Grafana
- Hands-on: Monitor suspicious container activity using Falco

4.2 Compliance and Governance

- CIS Benchmarks for Linux, Docker, Kubernetes
- ISO 27001, NIST Cybersecurity Framework
- Reporting and Audit Considerations

4.3 Project

Objective: Secure a sample application through the full DevSecOps pipeline

- Threat Modeling
- SAST, SCA, DAST Integration
- Container and IaC Security
- Secrets Handling
- CI/CD Pipeline with Policy Enforcement

- Deploy and Monitor Application Logs and Events